

EXPLAINER · POA&M

What You Can Put on a POA&M, and What You Cannot

A POA&M restores no SPRS points and cannot carry the highest-weight controls. Here are the rules that decide what actually belongs on one.

BY MAXINE · READING TIME · 4 MIN · POAM · CMMC · SPRS · NIST-800-171

Plan of Action and Milestones reads, to most program managers filling one out for the first time, like a second chance: list what is not done yet, promise a date, and the assessment proceeds as if the gap were already closed. It is not a second chance. It is a narrow, rule-bound exception to the requirement that every control be implemented before certification, and the rules that bound it are stricter than the paperwork suggests. Three of them govern what can go on the document at all. A fourth governs who is allowed to sign it.

What a POA&M cannot buy you

Start with the score, because it is the number a contracting officer actually reads. The DoD Assessment Methodology subtracts a weight of 5, 3, or 1 for every unimplemented control, and the subtraction does not know the difference between a control nobody has touched and a control with a signed remediation plan behind it - see [how that arithmetic actually runs](#). It stays in effect until the control is implemented, not until it is planned. Write a POA&M for a 5-point gap and the score posted to SPRS is still the lower number. A well-organized remediation plan reads as diligence to the program that wrote it and as an unmet requirement to the database that reports it, and the database is what the contracting officer sees first.

The second rule removes the option entirely rather than merely declining to credit it. Under the CMMC certification requirements, not every unimplemented control is POA&M-eligible, and the two exclusions that catch programs hardest both carry the maximum weight. 3.5.3, multifactor authentication, and 3.13.11, [FIPS-validated cryptography](#), cannot be deferred to a remediation plan for a passing Level 2 assessment; most of the requirement set's other 5-point controls face the same bar, with only a narrow set of exceptions. A remediation plan built around deferring the expensive controls is not a remediation plan. It is a plan to fail the assessment on precisely the items an assessor checks first, because the DoD weighted them at five points for the same reason a program manager is tempted to defer them: they are the ones that are hardest to fake and most expensive to fix.

The clock starts the day you file it

What a POA&M can do is buy time on the requirements that remain eligible, and the time is not open-ended. Conditional certification status runs on two clocks: a high-priority item is expected to close within 90 days, a standard item within 180, and filing the plan is what starts the count. Nothing about the clock cares whether the underlying work is hard.

Closure is not synonymous with finishing the underlying task. It requires the remediation actually implemented, the evidence of that implementation collected, the control re-tested against its NIST SP 800-171A assessment objectives rather than assumed to pass because the tool is now installed, the SPRS score updated to reflect the change, and the closure itself approved by a named risk owner. Skip that last step and a control can sit "done" in an engineer's private estimation for months while the stale, lower score a contracting officer is reading today never moves.

An unowned action is an action nobody has agreed to take, and an assessor reads a POA&M line that way on sight.

That named risk owner is the detail the whole clock depends on, and it is the most common defect in the artifact. A line item whose owner column reads "TBD" or "IT" has not identified a person; it has identified a department, or an intention to figure it out later, and neither can approve a closure or answer for a missed date. An assessor who finds that column empty, or filled with a title instead of a name, is not looking at a minor formatting gap. They are looking at a plan with no one accountable for keeping it, which is functionally the same defect as no plan at all - and it is why unapproved risk acceptance standing in for real remediation is an outright disqualifier rather than a deduction. MacTech's public CMMC reference server enforces that same governance mechanically: hand it a list of gaps and it returns structured entries with priority set by the SPRS weight and dates set by the 90/180 split, and it will not substitute a risk-acceptance shortcut for the rule. The internal control plane behind

A MacTech's own programs runs one unified POA&M model on the same logic, with lifecycle enforcement built into the record rather than left to whoever remembers to update a spreadsheet.

None of this makes the document useless. An eligible gap with a real owner and a defensible date is a legitimate answer to a real deficiency, and it buys 90 or 180 days a program would not otherwise have. What it does not do is make an assessment easier than the underlying requirements actually are. A **readiness check** that sorts your open gaps into what is POA&M-eligible and what has to close before an assessor ever arrives is worth running before the plan gets written, not after it gets rejected. ♦

FIELD COPY
ISSUE N° 023
POAM

0

SPRS POINTS A POA&M
RESTORES UNTIL THE
CONTROL IS ACTUALLY
IMPLEMENTED

90 / 180

DAYS TO CLOSE A HIGH-
PRIORITY VS. A STANDARD
POA&M LINE UNDER
CONDITIONAL STATUS

2

5-POINT REQUIREMENTS
BARRED FROM POA&M FOR
CERTIFICATION - 3.5.3 AND
3.13.11

♦ MACTECH'S PUBLIC POA&M REFERENCE

MacTech publishes a CMMC reference server in the public registry (com.mactechsolutionsllc.com/c) that turns a list of unimplemented controls into structured POA&M entries - deficiency, remediation, SPRS-weighted priority, target date - and returns the governance rules with them, including that unapproved risk acceptance in place of remediation disqualifies the assessment.

MORE ISSUES

mactechsolutionsllc.com/macazine
new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF
mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.
Published from Git, reviewed like code.